TSA 2021 and CDA

The Telecommunications (Security) Act 2021 in brief, and what it means for a retention and disclosure capability

Prepared for Michael Rossi
October 2026 — legal brief, not legal advice

In one paragraph

The Telecommunications (Security) Act 2021 amended the Communications Act 2003 to place a statutory duty on providers of public electronic communications networks and services to identify and reduce the risk of security compromises, and to prepare for and remediate them. The detail sits in the Electronic Communications (Security Measures) Regulations 2022 and a Code of Practice, tiered by provider size, with Ofcom as the regulator and fines of up to 10% of relevant turnover. For CDA the point is simple: the retention and disclosure estate is part of the network. It is inside the TSA perimeter, assessed by Ofcom to TSA standards, and cannot be run to lawful-intercept-team norms in isolation from enterprise security governance.

> **TALKING POINT**
> 'The CDA platform is a network asset under TSA. Ofcom will look at it with the same lens as the core, and the IPA's own 'same standard as business data' test now has a statutory floor to point at.'

1. What the Act does

Provision	Substance
s.105A Communications Act (inserted)	Duty to take appropriate and proportionate measures to identify and reduce the risks of security compromises, and to prepare for their occurrence
s.105B–C	Duty to take measures in response to a compromise; power for the Secretary of State to make Security Measures Regulations
s.105E–F	Codes of Practice: Ofcom must take them into account; non-compliance with a Code is evidence of breach of duty
s.105J–K	Duty to inform users and Ofcom of compromises with significant effect
s.105M–P	Ofcom's enforcement: information powers, assessments, directions, penalties up to 10% of relevant turnover or £100,000 per day
s.105Z1 onward	Designated vendor directions — the Secretary of State may restrict use of named high-risk vendors (the Huawei provisions)
Security Measures Regulations 2022	The 'what': network architecture, protection of data and functions, monitoring and analysis, supply chain, privileged access, patching, testing, governance, competency
Code of Practice (2022)	The 'how' and 'by when': Tier 1 (large, >£1bn turnover) by March 2024 / 2025 / 2027 for successive tranches; Tier 2 (>£50m) a year later; Tier 3 proportionate

'Security compromise' is defined broadly: anything that compromises availability, performance or functionality of the network, unauthorised access to or interference with it, or anything that compromises the confidentiality of signals or data. A wrongful disclosure from a retained-data store is a compromise of the confidentiality of data conveyed by the network — it is in scope.

2. The Regulations' themes, mapped to a CDA estate

Regulation theme	What it requires	CDA design consequence
Network architecture (reg 3)	Identify and segregate security-critical functions; protect their management; reduce exposure	The retention store, resolution and disclosure services are security-critical functions. Segregate them from business networks; put their management plane in a protected zone
Protection of data and network functions (reg 4)	Protect data conveyed and held; secure the signalling plane; control data egress	Encryption at rest with controlled keys; the disclosure interface is a formally governed egress point; signalling feeds into the store are protected in transit
Monitoring and analysis (reg 5)	Monitor security-critical functions; retain and analyse security logs for at least 13 months	Audit of every query and release, held for 13 months minimum — longer than most retained data. Volume reconciliation doubles as TSA monitoring
Supply chain (reg 6)	Understand and manage third-party risk; contractual security obligations; no unmanaged supplier access	The CDA course's vendor position is now a statutory expectation: no standing remote access, break-glass only, supervised and recorded; designated-vendor restrictions apply to the estate
Prevention of unauthorised access (reg 7)	Privileged access workstations; MFA; least privilege; no shared accounts; third-party access controls	Compartmentation of provisioning, data, disclosure and audit roles is the TSA pattern, not just the IPA one; per-request authorisation-bound access exceeds the baseline
Preparing for remediation (reg 8)	Ability to restore; backups protected; incident capability	Backups must exist and be secure — which collides with the IPA's deletion duty; crypto-shredding reconciles them
Patching and updates (reg 9)	Timely security patching, including of security-critical functions	The capability-impact question on every change applies to patches too: a patch that alters a feed is a notifiable change
Testing (reg 10)	Penetration and security testing of security-critical functions	The disclosure interface and resolution services are tested; the test evidence is part of the assurance pack
Governance (reg 11)	Board-level accountability for security; competent people; documented policies	The CDA design authority reports into the same governance; the named controller-level accountable owner from the processor/controller paper is the same person
Reviews (reg 12)	Annual review of measures	Fold the CDA assurance review into it

3. Where TSA meets the IPA

Topic	IPA 2016 says	TSA 2021 says	Reconciled position
Security standard for retained data	Same standard as the operator's own business data (s.92)	Appropriate and proportionate measures per the Regulations and Code	The TSA Code is the floor the IPA test points at; the IPA store is protected to at least the Code's security-critical-function standard
Who inspects	IPCO (compliance with the Act); ICO audits retained-data security under s.244	Ofcom (TSA compliance)	Three bodies, one estate; evidence pack must serve all three
Logs and audit	Reconstructable disclosures; audit outliving the data	13 months' security log retention minimum	Disclosure audit retained for the longer of the two; keep audit and retained data on separate lifecycles
Backups	Destroy retained data at end of period, including copies	Maintain secure, restorable backups	Per-partition keys destroyed at expiry; backups remain but are unreadable
Supplier access	Implicit in security duties	Explicit: control and monitor third-party access; designated-vendor directions	Vendor break-glass model, contractually bound, logged
Change	Notification notices (s.258A) for capability-affecting changes	Patch promptly; manage change to security-critical functions	A single change record with both a capability-impact and a security-impact question
Incidents	Report errors to IPCO; personal-data breaches to the ICO	Report significant compromises to Ofcom and users	Pre-agreed incident routing: which body, which threshold, which clock

4. Difficulties in practice

- **Perimeter blindness.** LI and retention estates have historically been run by a small, cleared team outside mainstream IT governance. TSA assessments will ask for them to be in the asset inventory, the risk register and the testing programme like any other security-critical function.
- **Tier timing.** Tier 1 operators' deadlines have passed for the first tranches; a CDA programme cannot claim a longer runway than the network it sits in.
- **Log retention exceeds data retention.** Thirteen months of security logs for a store whose data lives twelve: the audit will outlive the data it describes, which is what the CDA course wants anyway, but it must be designed, not assumed.
- **Supply chain.** Retention and mediation platforms are often a single specialist vendor with deep access. TSA makes the 'we trust them' answer unacceptable in writing.
- **Conflicting incident clocks.** ICO 72 hours, Ofcom 'without undue delay' for significant compromises, IPCO per the Code. Decide the routing before the incident.
- **Designated vendors.** If any component in the CDA path is from a vendor subject to a designated vendor direction, the removal timetable applies to it.

5. Questions to ask

- Is the retention and disclosure estate in the TSA asset inventory as a security-critical function, and in which tier's timetable?
- Who in the TSA governance structure is accountable for it, and is that the same person who owns the IPA capability?
- Are disclosure audit logs retained for at least thirteen months on a lifecycle separate from the retained data?
- Show me the vendor access model and the contract clauses that back it.
- Which incident routes — Ofcom, ICO, IPCO — are pre-agreed for a compromise of the retained store, and who decides on the day?
- Has the disclosure interface been penetration tested, and is the report in the assurance pack?

> **CAVEAT**
>
> Tier thresholds, deadlines and the Code's detailed measures are as understood at October 2026 and should be checked against the current Regulations, Code and Ofcom guidance before use as a design constraint.